

Seguridad y Resiliencia

Proyecto: Encuestas Inteligentes IA

Objetivo

Documentar los controles aplicados para proteger datos, credenciales y continuidad operativa del flujo automatizado Airtable - OpenAI - Slack/Gmail.

1. Principios de seguridad aplicados

Control	Implementacion actual	Riesgo mitigado
Minimizacion de datos	La llamada a IA envia solo Score y Comment. No se envian nombre, email ni identificadores de cliente.	Exposicion innecesaria de datos personales.
Gestion de credenciales	La API key de OpenAI se almacena en Credentials de Make y no dentro del prompt ni de Airtable.	Filtracion accidental de secretos.
Human-in-the-loop	Los casos sensibles pasan a Pending Human Approval, generan Human Review y alerta por Slack.	Acciones automatizadas sobre casos criticos sin validacion humana.
Trazabilidad	Airtable conserva estado, resumen de IA, indicador de revision humana, registros de Human Reviews y mensajes de error.	Falta de evidencia y dificultad de auditoria.
Control de fallos	Si falla HTTP/OpenAI, Make actualiza la encuesta con Status = 6. Error y guarda Error: Message antes de cerrar la rama.	Fallos silenciosos o registros en estado ambiguo.

2. Minimizacion de datos y uso de la IA

El modulo HTTP consume la API Responses de OpenAI. El cuerpo de la solicitud instruye a la IA a clasificar sentimiento y urgencia, generar un resumen y determinar si se requiere revision humana. Como entrada variable se mapean exclusivamente el puntaje de la encuesta y el comentario.

HTTP

Authentication type *
API key

Select the authentication type for an API call or authenticated webhook.

Credentials *
Agostina's API Key Auth key Add

For more information on how to create an API key connection to HTTP, see the [online Help](#).

URL *
https://api.openai.com/v1/responses

Enter the URL of an API endpoint (including the base URL), webhook, or webpage, beginning with [https://](#).

Method * Map
POST

Select the HTTP request method.

Headers Map
+ Add a header

Add custom headers to provide additional metadata or instructions for the request.

Query parameters Map
+ Add a parameter

Show advanced settings Cancel Save

Evidencia: autenticacion mediante API key gestionada en Make y endpoint de OpenAI.

HTTP

Select the format for the body of the request. This is mostly for POST, PUT, and PATCH methods or webhooks.

Body input method *
JSON string

Body content *

```
{
  "model": "gpt-5.6-luna",
  "input": "Analiza la siguiente respuesta de una encuesta de satisfaccion. Determina: sentimiento (positive, neutral o negative), urgencia (low, medium, high o critical), un resumen breve y si requiere revision humana. Requiere revision humana si hay amenaza legal, reclamo grave, posible dano, compensacion economica o una situacion especialmente sensible. Devuelve unicamente JSON valido con esta estructura: {\"sentiment\": \"\", \"urgency\": \"\", \"summary\": \"\", \"requi res_human_review\": false}. Puntuacion: 1. Score Comentario: 1. Comment \", \"max_output_tokens\": 300
}
```

Make sure to escape any JSON reserved characters placed within values.

Parse response Map
Yes No

This structures the output data so that it's easy to map. All mappable items will be available after you run the module once.

Show advanced settings Cancel Save

Evidencia: el body utiliza Score y Comment y limita la salida a 300 tokens.

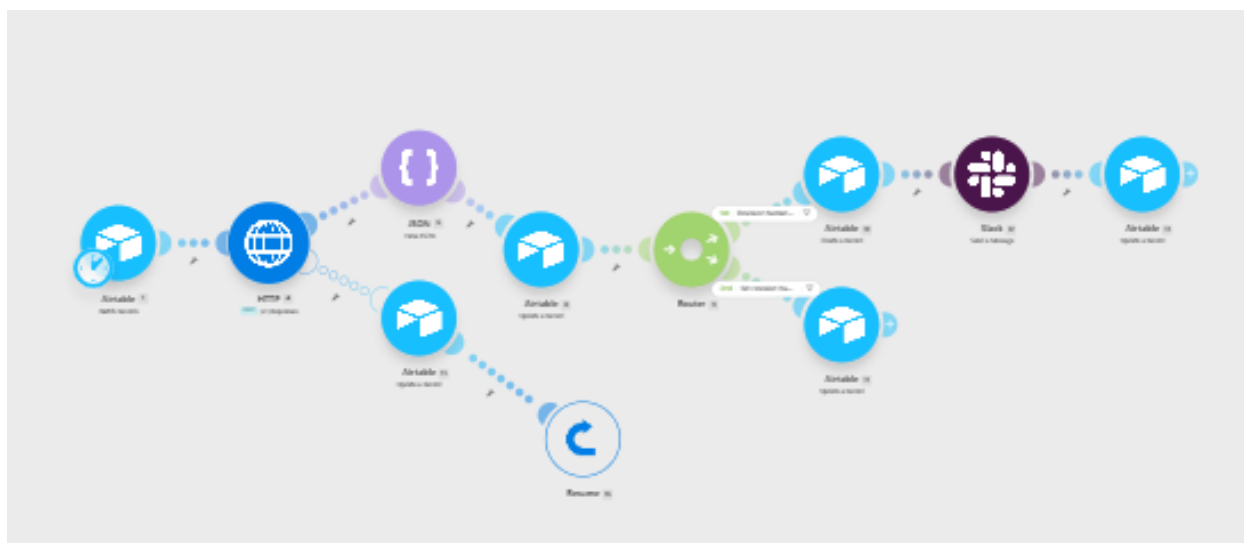
3. Human-in-the-loop (HITL)

Cuando la IA marca Requires human review = true, el Router deriva el registro a la rama de revision humana. Se crea un registro en Human Reviews, se envia una alerta por Slack y la encuesta original queda en 3. Pending Human Approval. Un segundo escenario observa Human Reviews y solo envia el correo cuando Status = Approved.

Etapas	Estado / control
IA detecta sensibilidad	Requires human review = true
Derivacion	Router -> Human Reviews + Slack
Espera	Survey Responses = 3. Pending Human Approval
Decision humana	Human Reviews: Pending -> Approved
Continuacion	Filtro Status = Approved -> Gmail

4. Manejo de errores y resiliencia

Se incorporo un Error Handler especifico sobre el modulo HTTP. La ruta de excepcion actualiza el mismo registro de Survey Responses utilizando el Record ID de Airtable, fija Status = 6. Error y almacena el mensaje devuelto por el error HTTP en el campo Error. Luego se utiliza Resume para cerrar el manejo del bundle.



Flujo final: HTTP exitoso continua por JSON; HTTP con error deriva a Airtable Update a Record y luego Resume.

5. Prevencion de loops y reprocesos

El proceso se controla mediante estados discretos en Airtable (Pending, Processed by AI, Pending Human Approval, Approved by Human, Completed y Error) y filtros de ruta. El segundo escenario solo continua cuando Human Reviews tiene Status = Approved. Esta separacion de estados evita que una aprobacion pendiente dispare el correo y reduce el riesgo de reprocesar indiscriminadamente registros ya tratados.

Como mejora futura, si el volumen creciera, se recomienda agregar una vista o condicion de entrada explicita para procesar solo registros en estado Pending y excluir de forma permanente Completed y Error salvo reproceso manual.

6. Pruebas de resiliencia recomendadas

Prueba	Resultado esperado
Caso normal positivo	Clasificación por IA y cierre por la ruta sin revisión humana.
Caso crítico	negative/critical -> Human Review -> Slack -> Pending Human Approval.
Aprobación humana	Cambio a Approved en Human Reviews -> filtro -> Gmail.
Falla de API/HTTP	Survey Responses pasa a 6. Error y se registra Error: Message.
Dato incompleto o respuesta inesperada	El escenario no debe ejecutar acciones sensibles sin validación; revisar historial de Make y registro Error si corresponde.

7. Conclusion

El prototipo aplica controles proporcionales a su alcance: minimiza los datos enviados a la IA, protege credenciales mediante el gestor de Make, incorpora validación humana para casos sensibles, mantiene trazabilidad en Airtable y registra fallos de la API en una ruta de error dedicada. Para una implementación productiva se recomienda complementar estos controles con políticas de acceso por rol, retención de datos, alertas operativas y pruebas periódicas del flujo de excepción.